

|            |                     |
|------------|---------------------|
| Student:   | Email:              |
| Dquez Carr | dquezcarr@gmail.com |

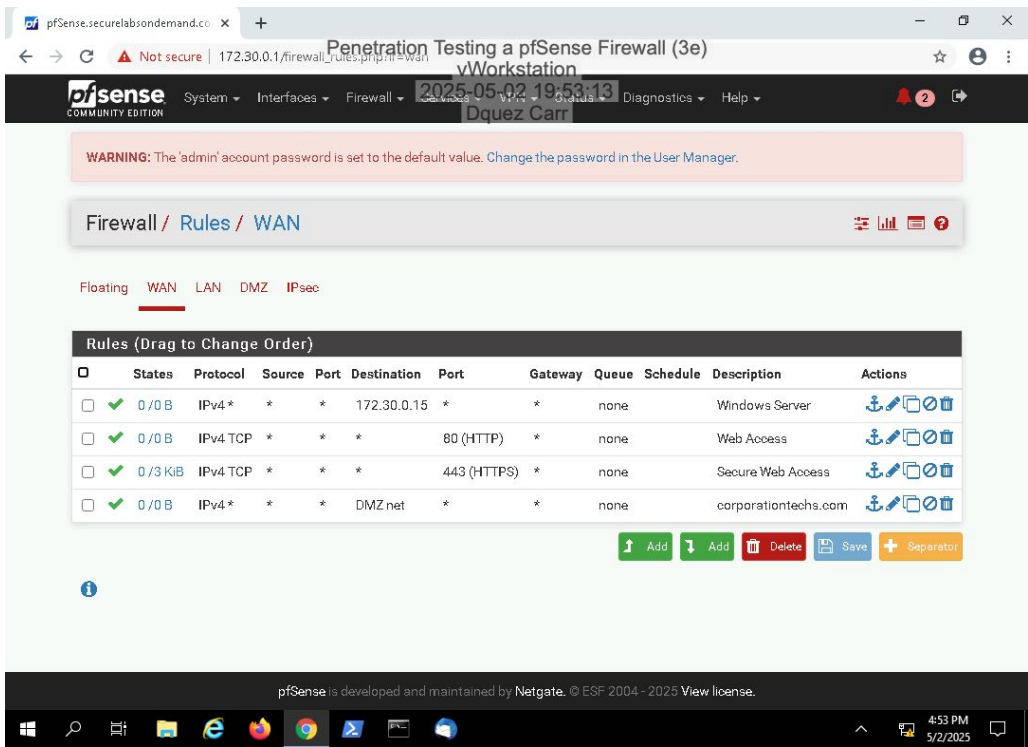
|                    |           |
|--------------------|-----------|
| Time on Task:      | Progress: |
| 5 hours, 6 minutes | 91%       |

Report Generated: Friday, May 2, 2025 at 10:07 PM

Section 1: Hands-On Demonstration

Part 1: Examine a pfSense Firewall Configuration

12. Make a screen capture showing the WAN rules table.



Part 2: Conduct a Penetration Test on the Network

11. Make a screen capture showing the *yourname* pen test scan results.

Incomplete

## 13. Make a screen capture showing the list of vulnerabilities.

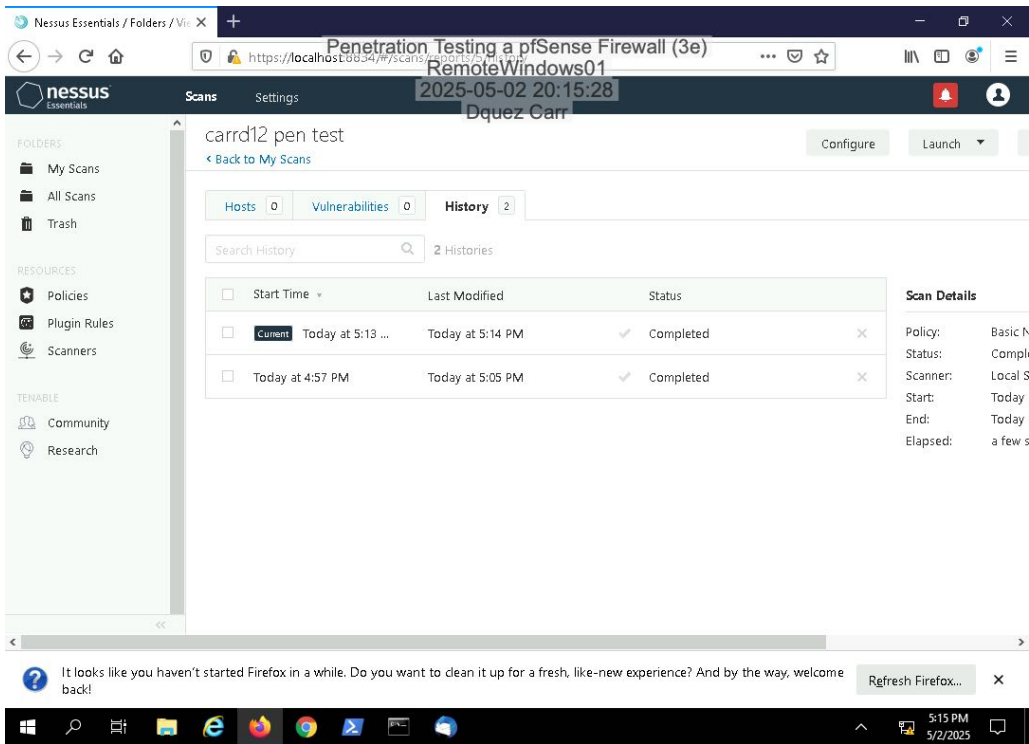
The screenshot shows the Nessus Essentials web interface in a browser window. The browser's address bar displays the URL `https://localhost:8834/#/scans/policies`. The page title is "carrd12 pen test". The interface includes a left sidebar with navigation options like "My Scans", "All Scans", "Trash", "Policies", "Policies (P)", "Scanners", "Community", and "Research". The main content area displays a table of vulnerabilities for the selected scan. The table has columns for "Sev", "Name", "Family", and "Count". The vulnerabilities listed are:

| Sev    | Name                        | Family           | Count |
|--------|-----------------------------|------------------|-------|
| MEDIUM | SSL Certificate Cannot ...  | General          | 2     |
| MEDIUM | SSL Self-Signed Certific... | General          | 2     |
| MEDIUM | jQuery 1.2 < 3.5.0 Mult...  | CGI abuses : XSS | 1     |
| MEDIUM | Microsoft Windows Re...     | Windows          | 1     |
| MEDIUM | SMB Signing not requir...   | Misc.            | 1     |
| MEDIUM | SSL Certificate Expiry      | General          | 1     |
| MEDIUM | SSL Medium Strength ...     | General          | 1     |

On the right side of the interface, there is a "Scan Details" section showing information about the scan, including the policy, status, scanner, start/end times, and elapsed time. Below this is a "Vulnerabilities" section with a donut chart showing the distribution of vulnerability counts by severity.

At the bottom of the browser window, there is a notification from Firefox stating: "It looks like you haven't started Firefox in a while. Do you want to clean it up for a fresh, like-new experience? And by the way, welcome back!"

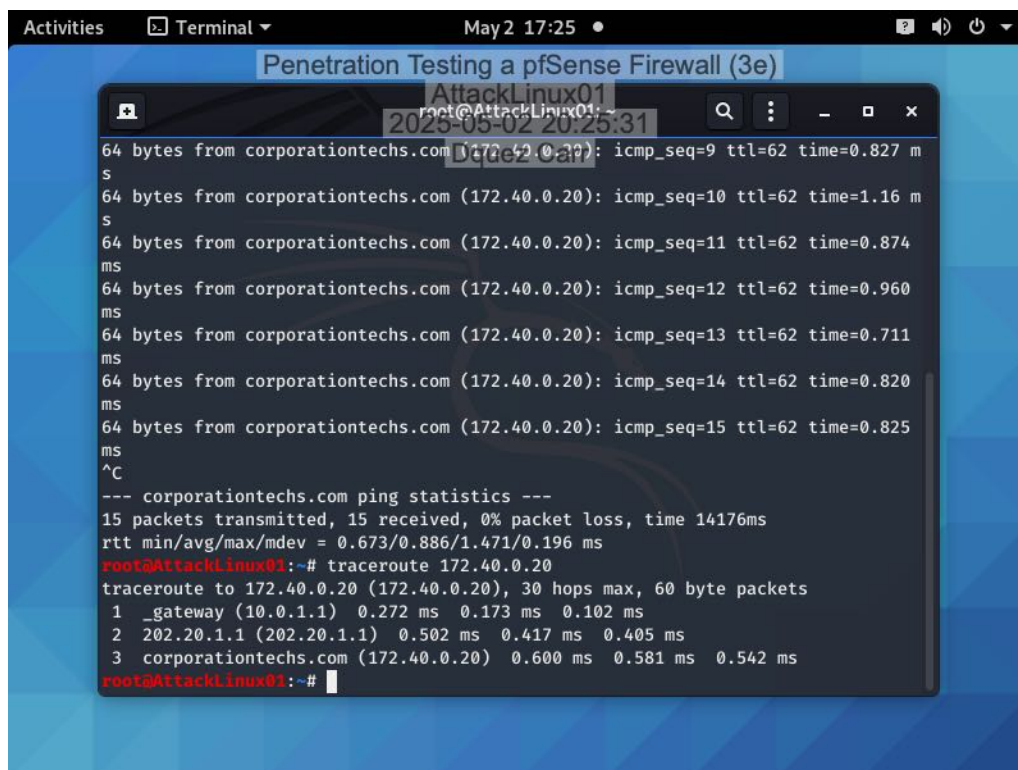
30. Make a screen capture showing the **updated vulnerability report summary**.



## Section 2: Applied Learning

### Part 1: Conduct a Port Scan on the Network

7. Make a screen capture showing the results of the traceroute command.



The screenshot shows a terminal window titled "Penetration Testing a pfSense Firewall (3e)" with a subtitle "AttackLinux01". The terminal output displays the results of a traceroute command to 172.40.0.20. The output shows 15 packets transmitted, 15 received, 0% packet loss, and a total time of 14176ms. The traceroute path consists of three hops: 1. \_gateway (10.0.1.1) with RTT values of 0.272 ms, 0.173 ms, and 0.102 ms; 2. 202.20.1.1 (202.20.1.1) with RTT values of 0.502 ms, 0.417 ms, and 0.405 ms; 3. corporationtechs.com (172.40.0.20) with RTT values of 0.600 ms, 0.581 ms, and 0.542 ms.

```
root@AttackLinux01:~# traceroute 172.40.0.20
traceroute to 172.40.0.20 (172.40.0.20), 30 hops max, 60 byte packets
 1 _gateway (10.0.1.1)  0.272 ms  0.173 ms  0.102 ms
 2 202.20.1.1 (202.20.1.1)  0.502 ms  0.417 ms  0.405 ms
 3 corporationtechs.com (172.40.0.20)  0.600 ms  0.581 ms  0.542 ms
root@AttackLinux01:~#
```

## Network Security, Firewalls, and VPNs, Third Edition - Lab 10

11. **Make a screen capture** showing the result of the **nmap** scan with OS detection activated.

```

3389/tcp open  ms-wbt-server Microsoft Windows 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
5901/tcp open  vnc VNC (protocol 3.8)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.80%E=4%D=5/2%Time=68156341P=x86_64-pc-linux-gnu(r(DNSVersionBindReqTCP,20,"0\x1e\x06\x81\x04\x01\x00\x00\x07version\xSF:04bind\0\x10\x03");
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.80%E=4%D=5/2%OT=53CT=1%CU=42145PV=N%DS=3%DC=1%G=Y%TM=681563D0
OS:%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=108%TI=I%II=I%SS=S%TS=U)OPS(
OS:O1=M5B4NW8NNSO2=M5B4NW8NNSO3=M5B4NW8O4=M5B4NW8NNSO5=M5B4NW8NNSO6=M5
OS:B4NNS)WIN(W1=FFFFW2=FFFFW3=FFFFW4=FFFFW5=FFFFW6=FF70)ECN(R=Y%DF=Y%T
OS:=80%W=FFFFO=M5B4NW8NNSCC=Y%Q=)T1(R=Y%DF=Y%T=80%S=O%A=S+%F=AS%RD=0%Q=)T
OS:2(R=N)T3(R=N)T4(R=N)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=N
OS:)T7(R=N)U1(R=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=9269%RUD
OS:=G)IE(R=Y%DFI=N%T=80%CD=Z)

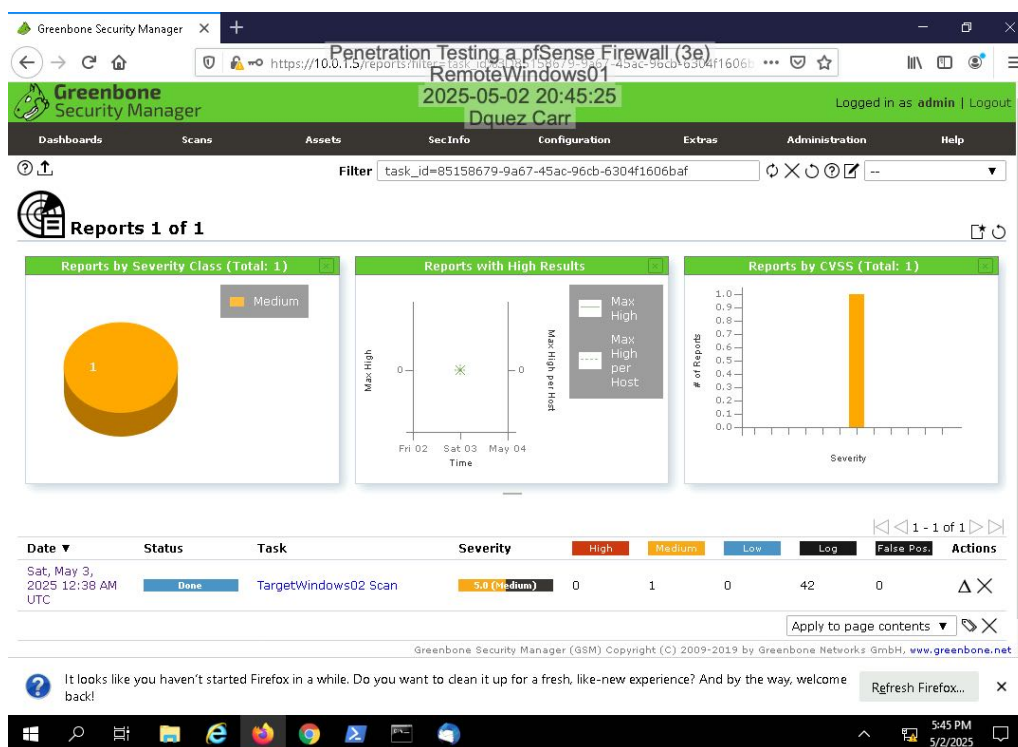
Network Distance: 3 hops
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 174.23 seconds
root@AttackLinux01:~#

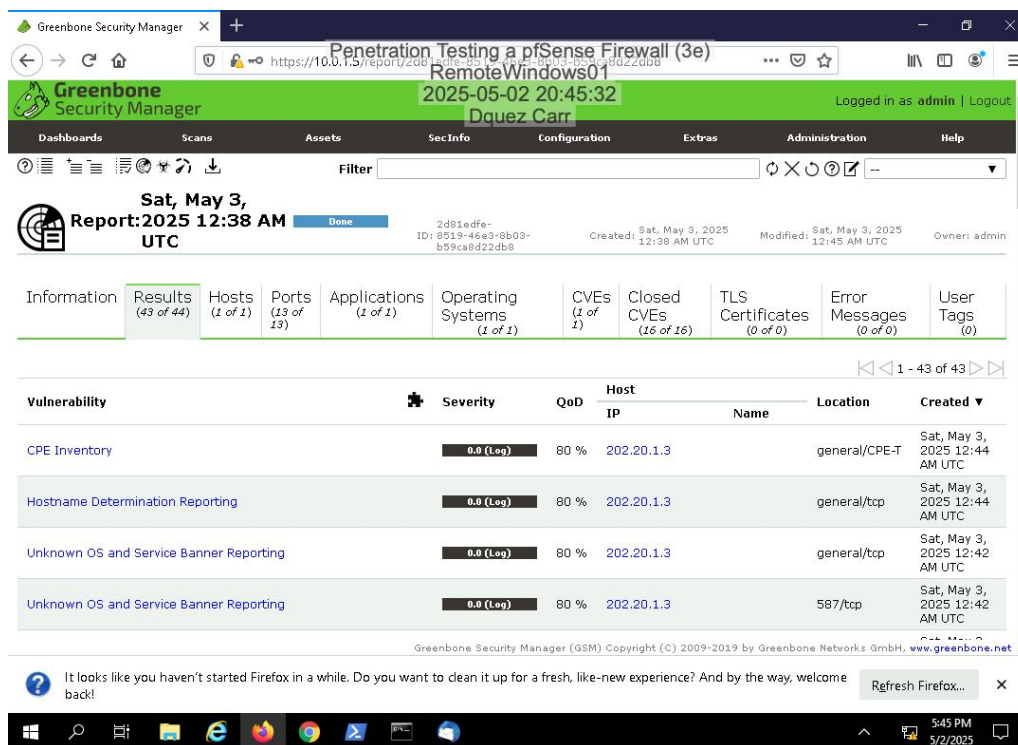
```

## Part 2: Conduct a Vulnerability Scan on the Network

## 12. Make a screen capture showing the OpenVAS scan report.



## 14. Make a screen capture showing the detailed OpenVAS scan results.



### Section 3: Challenge and Analysis

#### Part 1: Research DMZ Deployment Best Practices

Before beginning the technical portion of your penetration test, you decide to spend some time brushing up on best practices and common mistakes for DMZ deployments - both the network aspect and the servers located therein. Use the Internet to **research** DMZ deployments, then **identify** three best practices and one potential mistake or vulnerability.

It is crucial to adhere to best practices that reduce attack surfaces and guarantee layered security while deploying DMZ firewalls and web servers. First, segmentation is crucial, putting web servers and other services that are visible to the public in a different network zone (DMZ) that is cut off from the internal network. This restricts the possible harm that an attacker could inflict in the event that they breach a public service. Second, firewalls and security groups should be used to ensure least privilege access. This means that only essential traffic, such as HTTP/HTTPS (ports 80 and 443), should be allowed, and that SSH (port 22) should only be used by bastion hosts or trusted IPs. Third, patch management and system hardening are essential; to minimize vulnerabilities, servers in the DMZ should be updated often and devoid of superfluous services. Using default or weak credentials is a typical error in DMZ deployments, particularly for administration services like SSH. This raises the possibility of brute-force assaults and illegal access considerably. Additionally, exposing management ports like SSH (port 22) directly to the internet without additional protections such as multi-factor authentication, VPN access, or IP allowlisting makes the system more vulnerable. To prevent these mistakes and preserve a safe DMZ deployment, proper setup, frequent audits, and monitoring are required.

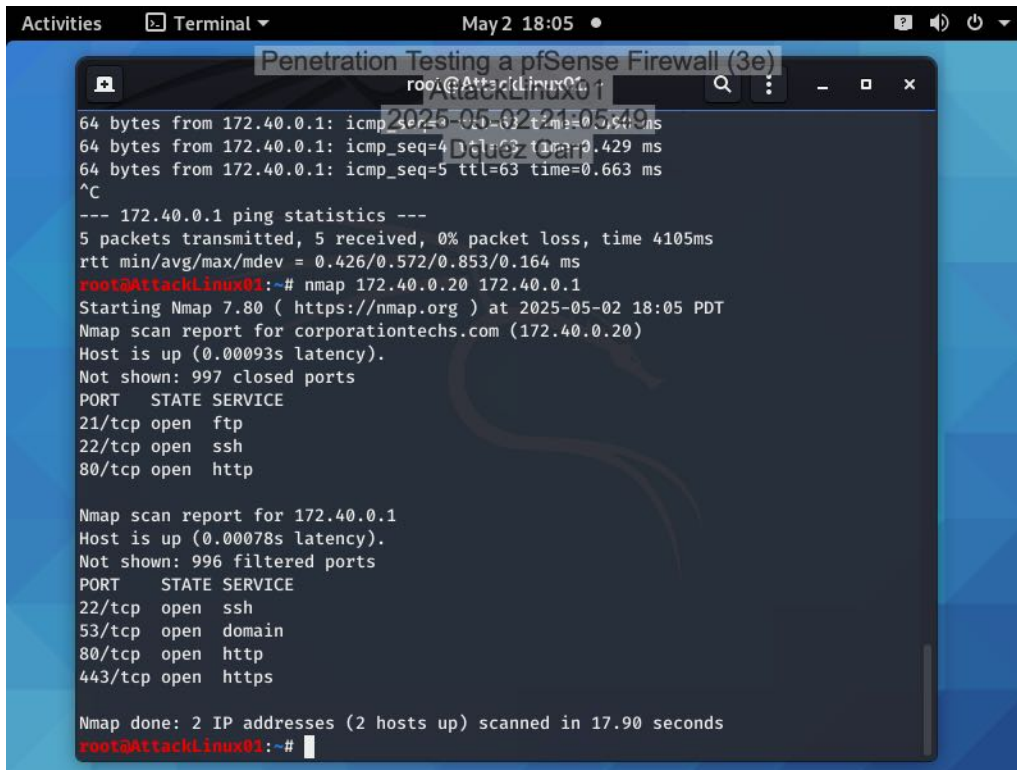
#### Part 2: Conduct a Penetration Test on the DMZ



## Penetration Testing a pfSense Firewall (3e)

Network Security, Firewalls, and VPNs, Third Edition - Lab 10

**Make a screen capture** showing the **open ports on the corporationtechs.com web server and the DMZ firewall interface.**



A terminal window titled "Penetration Testing a pfSense Firewall (3e)" is shown. The window displays the output of a ping command and an nmap scan. The ping command shows 5 packets transmitted with 0% packet loss. The nmap scan reports that the host is up and lists the following open ports: 21/tcp (ftp), 22/tcp (ssh), 80/tcp (http), 22/tcp (ssh), 53/tcp (domain), 80/tcp (http), and 443/tcp (https). The scan was completed in 17.90 seconds.

```
root@AttackLinux01:~# ping -c 5 172.40.0.1
64 bytes from 172.40.0.1: icmp_seq=1 ttl=63 time=0.544 ms
64 bytes from 172.40.0.1: icmp_seq=2 ttl=63 time=0.429 ms
64 bytes from 172.40.0.1: icmp_seq=3 ttl=63 time=0.429 ms
64 bytes from 172.40.0.1: icmp_seq=4 ttl=63 time=0.429 ms
64 bytes from 172.40.0.1: icmp_seq=5 ttl=63 time=0.663 ms
^C
--- 172.40.0.1 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4105ms
rtt min/avg/max/mdev = 0.426/0.572/0.853/0.164 ms
root@AttackLinux01:~# nmap 172.40.0.20 172.40.0.1
Starting Nmap 7.80 ( https://nmap.org ) at 2025-05-02 18:05 PDT
Nmap scan report for corporationtechs.com (172.40.0.20)
Host is up (0.00093s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Nmap scan report for 172.40.0.1
Host is up (0.00078s latency).
Not shown: 996 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https

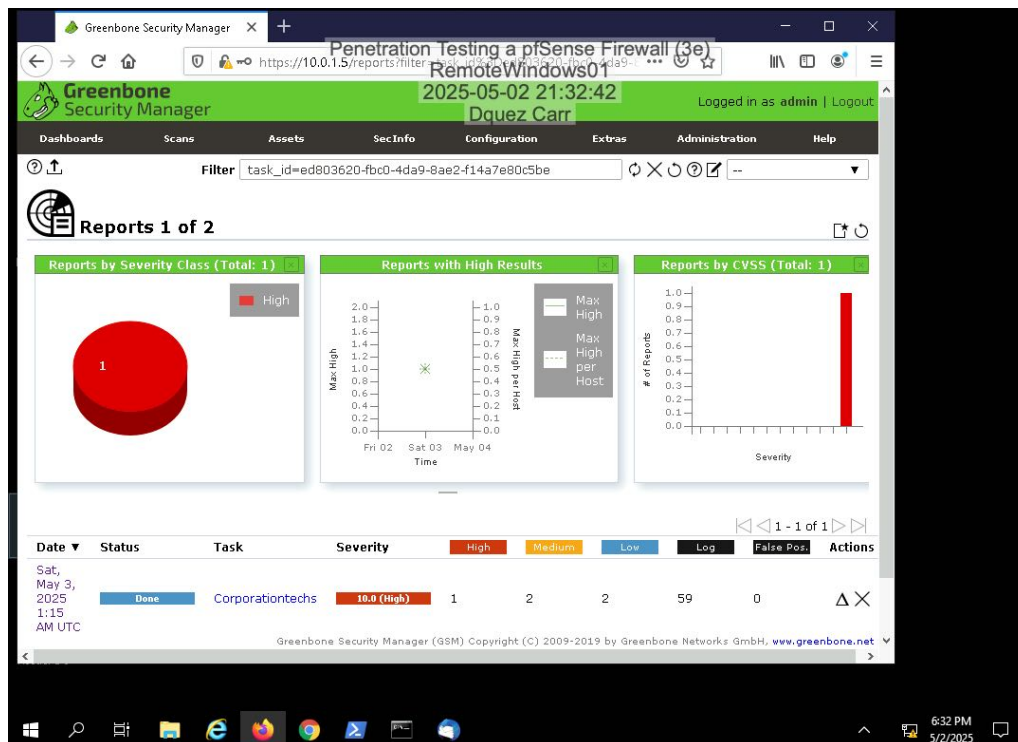
Nmap done: 2 IP addresses (2 hosts up) scanned in 17.90 seconds
root@AttackLinux01:~#
```



# Penetration Testing a pfSense Firewall (3e)

Network Security, Firewalls, and VPNs, Third Edition - Lab 10

Make a screen capture showing the **vulnerability scan results**.



## Part 3: Recommend Changes to the DMZ

Based on your research in Part 1 and your findings in Part 2, **prepare a brief summary** of recommended changes that Secure Labs on Demand should make to their DMZ deployment. Remember, your recommendations should apply to both the network configuration and the web server.

Using default SSH credentials is dangerous and should be avoided right once. Strong, one-of-a-kind SSH keys or complicated passwords should be created, and password-based authentication should be completely disabled in favor of key-based login. It is advised to limit SSH access using security group rules or network ACLs to permit connections from trusted IP addresses only, while port 80 HTTP and port 22 SSH are presently open. Clients and the web server can communicate securely if HTTPS 443 is enabled and all HTTP traffic is redirected to HTTPS. To find and eliminate new threats, the web server and DMZ host should go through routine vulnerability scans and audits. By putting in place logging and intrusion detection services inside the DMZ, the deployment will be more in line with industry best practices for protecting perimeter networks by monitoring traffic and identifying any attempts at illegal entry.